

Roles y privilegios en PostgreSQL

Concepto de rol

En PostgreSQL un rol es la entidad que puede ser dueña de objetos y recibir permisos sobre ellos. A partir de la versión ocho punto uno el rol sustituyó a los conceptos separados de usuario y grupo, de modo que ahora un solo objeto cumple las dos funciones. Un rol con atributo de conexión se comporta como usuario y un rol sin ese atributo se comporta como grupo. Los roles pertenecen al conjunto del servidor y no a una base de datos en particular.

ROL

CON LOGIN, se conecta al servidor y funciona como usuario

SIN LOGIN, no se conecta y funciona como grupo de permisos

Creación de roles

`CREATE ROLE consulta;`

`CREATE ROLE andres WITH LOGIN PASSWORD 'clave123';`

`CREATE USER capturista WITH PASSWORD 'clave456';`

La sentencia `CREATE USER` es equivalente a `CREATE ROLE` con el atributo `LOGIN` incluido.

Atributos de un rol

LOGIN. Permite que el rol se conecte al servidor.

SUPERUSER. Omite toda verificación de permisos. Debe otorgarse solo al administrador.

CREATEDB. Permite crear bases de datos.

CREATEROLE. Permite crear, modificar y eliminar otros roles.

INHERIT. Hace que el rol use de forma automática los permisos de los roles a los que pertenece. Es el valor por omisión.

REPLICATION. Permite iniciar conexiones de replicación.

PASSWORD. Define la contraseña del rol.

VALID UNTIL. Establece la fecha en la que expira la contraseña.

CONNECTION LIMIT. Limita el número de conexiones simultáneas del rol.

```
CREATE ROLE auditor WITH LOGIN  
  PASSWORD 'audita2026'  
  VALID UNTIL '2027-01-31'  
  CONNECTION LIMIT 3  
  NOSUPERUSER NOCREATEDB NOCREATE ROLE;
```

Concepto de privilegio

El privilegio es el permiso concreto que un rol tiene sobre un objeto de la base de datos. Al crearse un objeto, su dueño recibe todos los privilegios sobre él y es el único que puede otorgarlos a otros roles.

Privilegios principales

Privilegio	Permite	Se aplica sobre
SELECT	Consultar renglones	Tabla, vista, columna
INSERT	Agregar renglones	Tabla, columna
UPDATE	Modificar renglones	Tabla, columna
DELETE	Eliminar renglones	Tabla
TRUNCATE	Vaciar la tabla completa	Tabla
REFERENCES	Crear llaves foráneas hacia ella	Tabla, columna
TRIGGER	Crear disparadores	Tabla
CONNECT	Conectarse	Base de datos
CREATE	Crear objetos	Base de datos, esquema
TEMPORARY	Crear tablas temporales	Base de datos
USAGE	Usar el objeto	Esquema, secuencia, lenguaje
EXECUTE	Ejecutar	Función, procedimiento

Otorgar y retirar privilegios

`GRANT SELECT ON alumno TO consulta;`

`GRANT SELECT, INSERT, UPDATE ON alumno TO capturista;`

`GRANT ALL PRIVILEGES ON alumno TO andres;`

`GRANT SELECT ON ALL TABLES IN SCHEMA public TO consulta;`

`REVOKE UPDATE ON alumno FROM capturista;`

`REVOKE ALL ON alumno FROM consulta;`

Privilegios por columna

`GRANT SELECT (num_cta, nombre) ON alumno TO consulta;`

`GRANT UPDATE (promedio) ON alumno TO capturista;`

Opción de otorgar a terceros

Cuando un privilegio se concede con la cláusula `WITH GRANT OPTION`, el rol que lo recibe puede a su vez concederlo a otros roles. Para retirarlo se usa la cláusula `CASCADE`, que elimina también los permisos que ese rol haya otorgado.

`GRANT SELECT ON alumno TO jefe WITH GRANT OPTION;`

`REVOKE SELECT ON alumno FROM jefe CASCADE;`

Roles como grupos y herencia

Un rol se agrega a otro con `GRANT`, lo que convierte al primero en miembro del segundo y le permite usar sus privilegios. Si el rol tiene el atributo `INHERIT` los usa de forma automática, y si tiene `NOINHERIT` debe activarlos con la sentencia `SET ROLE`.

admin_escolar

capturista

andres

consulta

adriana

```
CREATE ROLE admin_escolar;  
CREATE ROLE capturista;  
CREATE ROLE consulta;
```

```
GRANT capturista TO andres;  
GRANT consulta TO adriana;  
GRANT capturista TO admin_escolar;  
GRANT consulta TO admin_escolar;
```

```
SET ROLE capturista;  
RESET ROLE;
```

El rol PUBLIC

PUBLIC es un rol implícito al que pertenecen todos los roles del servidor. Todo privilegio otorgado a PUBLIC lo reciben todos. Por omisión PUBLIC tiene permiso de conectarse a las bases y de usar el esquema public, por lo que en un servidor de producción conviene retirarlo.

```
REVOKE ALL ON DATABASE escuela FROM PUBLIC;
```

```
REVOKE CREATE ON SCHEMA public FROM PUBLIC;
```

Privilegios por omisión

Los privilegios se aplican solo a los objetos que ya existen. Para que las tablas creadas en el futuro reciban los permisos de forma automática se usa ALTER DEFAULT PRIVILEGES.

```
ALTER DEFAULT PRIVILEGES IN SCHEMA public  
GRANT SELECT ON TABLES TO consulta;
```

Consulta de roles y privilegios

\du

```
SELECT rolname, rolsuper, rolcreatedb, rolcanlogin  
FROM pg_roles  
ORDER BY rolname;
```

```
SELECT grantee, privilege_type  
FROM information_schema.table_privileges  
WHERE table_name = 'alumno';
```

```
SELECT has_table_privilege('capturista', 'alumno', 'INSERT');
```

Modificación y eliminación de roles

```
ALTER ROLE capturista WITH PASSWORD 'nueva2026';
```

```
ALTER ROLE capturista NOLOGIN;
```

```
REVOKE consulta FROM adriana;
```

```
REASSIGN OWNED BY capturista TO admin_escolar;  
DROP OWNED BY capturista;  
DROP ROLE capturista;
```

Un rol no puede eliminarse mientras sea dueño de algún objeto o conserve privilegios, por lo que primero se transfiere la propiedad y se retiran sus permisos.

Ejemplo completo

```
CREATE DATABASE escuela;
```

```
CREATE ROLE lector;
```

```
CREATE ROLE capturista;
```

```
CREATE ROLE andres WITH LOGIN PASSWORD 'andr2026';
```

```
CREATE ROLE adriana WITH LOGIN PASSWORD 'adr2026';
```

```
GRANT CONNECT ON DATABASE escuela TO lector, capturista;
```

```
GRANT USAGE ON SCHEMA public TO lector, capturista;
```

```
GRANT SELECT ON alumno TO lector;
```

```
GRANT SELECT, INSERT, UPDATE ON alumno TO capturista;
```

```
GRANT lector TO adriana;
```

```
GRANT capturista TO andres;
```

Conclusión

El manejo de roles y privilegios es el mecanismo con el que PostgreSQL garantiza la seguridad de la información. La práctica correcta consiste en crear roles de grupo que representen funciones dentro de la organización, otorgarles únicamente los privilegios mínimos que necesitan y después asignar esos grupos a los usuarios reales. Con ello se evita administrar permisos uno por uno y se reduce el riesgo de que alguien acceda a datos que no le corresponden.